診断で確認する観点

医院の情報管理と運用　1 / 2

確認項目のサンプルです。実際の対象は医院の構成と許可範囲に合わせて合意します。診断済み・安全性の保証を示すものではありません。

No.	確認項目	医院で起こり得る問題	確認する内容
01	患者情報の保存と暗号化	患者情報を関係のない人に見られる	問診・連絡先・添付ファイルについて、保存場所、読める人、通信中と保存時の保護を確認。暗号化があっても権限のある人からの不正取得は別に確認します。
02	バックアップと復元	障害や改ざん後に診療情報を戻せない	バックアップの暗号化、保管世代、削除権限、復元に必要な鍵を確認。取っているだけでなく、復元できるかを確認します。
03	患者番号・照合情報	別の患者に情報や会計をひも付ける	予約・問診・会計間で、別の患者にひも付かないかを確認。番号だけで本人を特定できると決めつけず、番号と実名の対応表も保護します。
04	大量取得の検知と停止	患者情報の持ち出しに気づけない	普段と異なる大量閲覧・一括出力に気づけるか。通知先、利用停止の権限、停止後の再開条件を確認します。
05	ログイン状態と端末紛失	紛失した端末から情報を見られる	共有PC・スマートフォンのログイン期限、紛失時の全端末ログアウト、端末内やログへの情報保存を確認します。
06	スタッフ・制作会社の権限	担当外の情報を閲覧・変更できてしまう	受付・医師・院長・制作会社の権限を整理。画面の非表示だけでなく、サーバー側でも閲覧・変更を拒否できるかを確認します。
07	ソフトウェア・フォームの弱点	既知の弱点や不正な入力を悪用される	CMS・PHP・プラグイン等の版と修正状況、問い合わせ・ファイル添付などの入力処理を確認。公開情報だけで版を断定しません。

報告では「問題を確認」「追加確認が必要」「確認済み」「対象外」を区別し、根拠・担当・期限・再確認結果を記載します。

診断で確認する観点

医院の情報管理と運用　2 / 2

確認項目のサンプルです。実際の対象は医院の構成と許可範囲に合わせて合意します。診断済み・安全性の保証を示すものではありません。

No.	確認項目	医院で起こり得る問題	確認する内容
08	本人確認と再設定	退職者や第三者が管理者として入れる	管理者の多要素認証・パスキー、復旧時の本人確認、退職者の利用停止を確認。再設定が抜け道にならないかも確認します。
09	一括出力・ダウンロード	出力した患者一覧が院外へ広がる	患者一覧等を出力できる人、対象件数、保存先、共有リンクの期限・失効を確認。通信の暗号化と出力後のコピーも確認します。
10	サーバー・鍵・本番変更の権限	保守権限や接続キーを悪用される	閲覧、更新、鍵管理、バックアップ削除の権限を整理。不要な接続キー、保守経路、作業承認と記録を確認します。
11	連続ログイン・フォーム連打	連打で業務が止まる・送信費用が増える	ログイン失敗、SMS再送、問い合わせ連打の回数制限を確認。医院内の共有回線からの正常利用を妨げないかも確認します。
12	外部サービスとの連携	外部への誤送信や連携停止が起きる	送受信先、項目、権限、鍵、失効、入力検証、再送を一覧化。ブラウザー経由・ファイル転記・自動通知も対象に含めます。
13	操作記録・事故対応	事故の範囲や原因を追えず対応が遅れる	誰が何をしたかの記録、ログの保存と保護、異常時の連絡・停止・復旧を確認。侵入の有無を調べる専門調査とは範囲を区別します。
14	不要なデータ・コピーの削除	不要なコピーから情報が漏れる	業務上必要な保持期間を決め、問い合わせ、出力ファイル、共有シート、ログなどの不要コピーを整理。必要な記録を誤って消さないかも確認します。

報告では「問題を確認」「追加確認が必要」「確認済み」「対象外」を区別し、根拠・担当・期限・再確認結果を記載します。

診断で確認する観点

外部サービスとの連携　1 / 2

医院側の設定と提供会社側の仕様・回答を分けて確認します。外部サービス内部の検査には、提供会社の許可が必要です。

連携先／渡る情報の例	確認する問題・根拠	確認を担う人	停止・障害・再開
Web予約・Web問診 **氏名・連絡先・予約日時・症状など**	URLやアクセス解析に氏名・症状が混ざらないか。予約番号だけで他の患者の情報を見られないか。 確認資料：テスト患者の送受信記録、閲覧権限、保存期間、データ出力・削除方法。	医院が契約・利用者・送信項目を確認。制作会社が接続設定を確認。提供会社がサービス内部を確認。	障害時は電話受付へ切り替え。復旧後に予約の抜け・重複を照合。
オンライン診療・電子カルテ連携 **患者識別子・診療関連情報・添付ファイルなど**	別の患者へのひも付け、過剰な取得権限、失敗時の部分更新を防げるか。 確認資料：送信項目一覧、患者照合の仕様、テストデータによる取込・拒否・再送の記録。	医院と各提供会社が対象範囲を合意。制作会社が医院側の連携部分を確認。	連携停止と診療継続の手順、未反映データの照合。内部の診断には提供会社の許可が必要。
決済・会計連携 **決済用の識別情報・金額・支払状態**	カード情報を医院HPやログに不要に保存していないか。偽の支払完了通知や再送で二重請求にならないか。 確認資料：テスト環境で通知の送信元確認、重複防止、金額照合、返金・取消権限を確認。	医院が契約・返金権限、制作会社が連携、決済会社が内部処理を確認。	障害時の未決済一覧と手動照合。再送時に同じ請求を重ねない。
LINE・メール・SMS **宛先・予約案内・認証コード・問い合わせ通知**	通知本文やロック画面に症状を載せすぎていないか。送信キー流出時に大量送信を止められるか。 確認資料：テスト宛先への通知内容、送信専用権限、コードの期限・試行制限、誤送信時の連絡先。	医院が宛先と本文、制作会社が送信設定、提供会社が配信基盤を確認。	送信停止・キー失効・交換、送信量上限、失敗時の再送と重複通知の抑制。

実際の連携先・送信項目・保存先・権限・接続キーの失効方法を一覧化します。報告書に患者情報や秘密の接続キーそのものは載せません。

診断で確認する観点

外部サービスとの連携　2 / 2

医院側の設定と提供会社側の仕様・回答を分けて確認します。外部サービス内部の検査には、提供会社の許可が必要です。

連携先／渡る情報の例	確認する問題・根拠	確認を担う人	停止・障害・再開
アクセス解析・広告・地図・外部スクリプト **閲覧URL・端末情報・イベント情報など**	問診の内容や患者識別子がURL・イベント・録画に混ざらないか。不要な外部コードが残っていないか。 確認資料：テスト入力時の通信先一覧、送信パラメーター、適用ページ、タグ変更権限。	医院が利用目的、制作会社がタグと送信内容、提供会社が仕様を確認。	タグの停止・削除と代替表示。外部コード更新時の確認担当を決める。
クラウド保存・共有シート・業務チャット **問い合わせ・添付画像・集計表・通知など**	誰でも開ける共有リンク、退職者の閲覧権限、複製された患者情報が残っていないか。 確認資料：共有設定、閲覧者一覧、連携用アカウント権限、ダウンロード記録、削除の実施記録。	医院が共有相手と保持期間、制作会社が転記・保存設定を確認。	共有解除・連携停止・既発行リンクの扱い。残ったコピーとバックアップも確認。
外部ログイン・連携用の鍵 **認証結果・利用者ID・接続用の秘密情報**	ログイン成功を正しく確認しているか。退職・契約終了後も古い接続キーで使えないか。 確認資料：接続先、権限、期限、失効・交換手順。本人確認の再設定経路も確認。	医院が利用者の承認・停止、制作会社が認証と鍵管理、提供会社が仕様を確認。	全端末ログアウト、接続キーの失効、再登録時の本人確認。秘密情報そのものは報告書に載せない。
保守・エラー通知・バックアップ **操作記録・URL・エラー内容・復元用データ**	エラー通知に問診本文や認証情報が出ていないか。保守アカウントからバックアップまで削除できないか。 確認資料：通知の除外設定、遠隔保守の本人確認・作業履歴、保存先・鍵の権限、復元テスト。	医院が作業承認、制作・保守会社が権限・ログ・復元、提供会社が基盤を確認。	休日の連絡先、遠隔接続の停止、隔離環境への復元、連携再開後のデータ照合。

実際の連携先・送信項目・保存先・権限・接続キーの失効方法を一覧化します。報告書に患者情報や秘密の接続キーそのものは載せません。